

THOM HASTINGS, Application Security Penetration Tester

555 15th Ave. E. Apt. 510
Cell: (314) 324-2111

Seattle, Washington 98112 <https://linkedin.com/in/ThomHastings>
tghastings@gmail.com or thom@attackvector.org

WORK EXPERIENCE IN SECURITY CONSULTING AND APPLICATION PENETRATION TESTING

Costco Wholesale Corporation – Senior Security Engineer

December 2024 to present

Information Security department, Cybersecurity Engineering division, Application Security team. Responsible for Mobile Application Security Testing (MAST) and Bug Bounty Program (BBP). Validates findings. Also tasked with Interactive Application Security Testing (IAST) and sharing team's responsibility for Static Application Security Testing (SAST), Dynamic Application Security Testing (DAST), and Software Composition Analysis (SCA). Member of Technical Review Board (TRB). Works with development teams to integrate security into the Software Development Lifecycle (SDLC). Uses principles of "secure by design."

Summit Security Group LLC – Security Engineer

October 2022 to March 2024

Application and network penetration testing engagements, cybersecurity consulting, and state contracts. Source code audits for a variety of languages. Supporting clients for various audit frameworks such as PCI and FedRAMP.

DigitSec Inc – Cybersecurity Consultant

July 2021 to October 2022

Vulnerability scanned 41,203 Salesforce sites for security weaknesses and PII exposure using Python PoC and Bash. Performing software-as-a-service security, web application penetration testing and network penetration testing.

Freelance Cybersecurity Consultant

April 2019 to July 2021

Following a sabbatical for medical reasons, did cybersecurity consulting for private clients and participated in private bug bounty programs. Developed exploits. Improved hacking skills with exercises such as Capture-The-Flag and wargames on sites such as TryHackMe, HackTheBox, VulnHub, and Offensive Security Proving Grounds.

Oracle Cloud Infrastructure Offensive Security Group – Red Team

March 2018 to March 2019

Wrote automated network reconnaissance scripts to utilize Shodan and nmap for external and internal attackers. Worked with blue teams directly conducting attack simulation and attack & defend scenarios. Used internal incident reporting and escalated through the reporting chain. Found vulnerabilities in Oracle's new cloud product, and made sure that these were responded to. Used a Kali Linux box for penetration testing as well as a separate primary workstation for business duties. Primarily wrote scripts in Python, but used Linux bash as well. Challenged myself to break into over 100 systems in under an hour and did so, compromising 117 systems. Specialized in deserialization vulnerability research, using open source tools to come up with up to 43 new 0day vulnerabilities in Oracle WebLogic that was being integrated into Oracle Cloud. Used scripts to automate the reconnaissance phase of penetration testing. Used scripts to automate the vulnerability discovery phase of vulnerability research. Performed white box, grey box, and black box testing. Conducted internal penetration testing and Red Team exercises. Performed web application security testing including OWASP Top Ten. Performed fuzzing of binaries and APIs as part of static and dynamic analysis during assessments. Audited Java and C code.

Charter Communications d.b.a. Spectrum – Offensive Security Team Lead

March 2017 to August 2017

Led Attack & Penetration Testing a.k.a. "Ethical Hacking" team with Spectrum's Offensive Security group. Extensive use of Open Source penetration testing tools, based out of a Kali VM on a Windows 7 box. Scripted, modified, and made heavy use of OpenVAS. Metasploited my way around the networks of 3 legacy companies post-merger. Used Qualys too. Worked both days and nights following office and testing procedure. Consistently supplemented primary duties to fight fires or find quick answers in an ancillary incident response role, aiding Cyber Attack & Defense. Crunched numbers and presented them in meetings big and small. Wrote PowerShell scripts. Leveraged ServiceNow for metrics and reporting. Brought company IT security practice and policy toward PCI and NIST compliance. Led & managed Agile SCRUM Stand-Ups developing open source tools and Six-Sigma RACI matrices.

CenturyLink Cloud: SAVVISdirect – Cloud Application Analyst

June 2016 to February 2017

Troubleshoot issues related to Linux web hosting, Microsoft Office 365, CloudFax, and Symantec antivirus. Worked with DNS, Wordpress, Site builder, Odin (Parallels), GoMobi, Microsoft Office 365 and Microsoft Exchange. Work on Linux Apache and Windows based servers, allocating webspace, webmail and other web hosting needs. Case documentation and escalation for incidents and requests in a timely and efficient manner. Business application support, cloud applications and web hosting support. Utilized the BMC Remedy ticketing system for reporting.

Prindiville & Associates – Licensed Private Investigator

April 2016 to February 2017

Expanded business offering into online investigation. Combined experience to perform digital forensics, open source intelligence, RF sniffing and dumpster diving. Drafted investigative documents such as profiles, dossiers, and evidence packets. Used software like Maltego and CaseFile for graphing, visualization, data mining, reporting, and analysis. Applied targeted research and creative thinking with tenacious diligence to generate leads, and report findings. At the time was a Licensed Private Investigator in the state of Missouri, specialist in OSINT.

Kaldi's Coffee on behalf of Schnuck's Markets – Coffee Barista

October 2015 to May 2016

Served as manager-on-duty for the coffee bar at my local supermarket. Managed ordering and inventory, and maintained product displays. Made many Pumpkin Spice Lattes, and thoroughly cleaned the place nightly. Knowledgeable in dozens of types of teas and coffees, as well as various specialty and boutique coffee drinks.

FortSec d.b.a. ScoutSwarm.com – Open-Source Intelligence Analyst

May to August 2015

Used sock-puppet accounts and false identities to infiltrate, profile, and gather information and intelligence on Deep Web cybercriminal activity. Performed and wrote reports on research of cybercriminal activity on the Deep Web, such as identifying Darknet markets. This intelligence was then built into Scout Swarm's analysis engine and feed product, now GroupSense.io.

Express Scripts Inc. under TekSystems subcontract – IT Security Analyst

September to October 2014

Worked on two teams, one focused on managing threats to and vulnerabilities in the network, such as automating Qualys scans, and another team on digital forensics and incident response, including managing logs with LogLogic.

Packt Publishing – Volunteer Technical Reviewer

August to September 2013

Performed technical content review and English grammatical editing for the book Instant Kali Linux by Abhinav Singh, published by Packt Publishing Ltd, UK.

St. Louis University – Advanced Technology Group Security Admin

August 2011 to August 2013

Conducted vulnerability assessments of university IT infrastructure, performed Linux admin for their High Performance Computing (HPC) cluster running Rocks, a version of CentOS (Red Hat Linux), and wrote Linux security & utility scripts in Bash, Python, Perl, and other programming languages, even Fortran.

DeJargonAte.com – Start-up Cofounder, President of Software Design

January 2011 to September 2011

Worked on an early-phase startup while in school, competing in computer-aided translation space (e.g. Spanish to English). Through guidance with both linguistics and computer science professors, we had believed that we could have a competitive edge through better machine translation preprocessing software. Partner left for SpaceX.

ReadyTech – On-Call Tech Support and Test Laboratory Technician

March 2010 to May 2010

Imaged from hard drives, prepared configuration for both Linux and Windows Virtual Machines, deployed them, and troubleshooted customer connectivity issues via phone or using Bomgar for remote desktop support, with an on-call rotation servicing global time-zones. Monitored sanity checks on server and VM configuration and deployment. Used Remedy ticketing system.

Primer Labs – Start-up Initiative on The Young Lady's Illustrated Primer

August 2009 to December 2010

Worked on early-phase game design projects for Primer Labs. Focused on open curricula and dynamic narrative. Heavily inspired by Neal Stephenson's work, "A Young Lady's Illustrated Primer," we were working on a universal educational video game, accessible to all. Later rebranded "Code Hero."

Open Jar Foundation – Typographer and Editor

November 2007 to February 2008

Digitized and edited The Magaziner-Maxwell Report (a.k.a. "Draft of a Working Paper for Education at Brown University") by Ira Magaziner, Elliot Maxwell, et al. Did this while attending Eugene Lang College The New School.

TechNet Tyler – On-Site Hardware Repair Technician

June 2008 to August 2008

Managed my own scheduling of onsite computer hardware repair and customer support. Traveled through Missouri and Illinois to work on Dell computers. Was personally responsible for contacting customers and arranging appointments for onsite repair. QualXserv, Dell Certified System Expert #519346.

Chaminade College Preparatory – IT Summer Staff

June 2004 to August 2004

Troubleshooted general IT problems and questions, performed hardware repair, imaged, configured, and set up new machines. Facilitated in setup of Windows 2003 servers. Tested network security through penetration testing.

ACADEMIC & TECHNICAL PUBLICATIONS

Spear-phishing, PDF and Countermeasures – *PenTest Magazine*
co-authored with Martha Bakken and Kristine Ivarsoy

Extra Issue 07 – 2012

Hacking that Feels “Fun” – *PenTest Magazine*
earliest known press for Armitage hacking tool

Starter Kit Issue 01 – 2011

Open Translation Tools – *FLOSS Manuals*
co-authored with 32 other expert authors during a week-long agile “Book Sprint”

June 2009

COLLEGIATE LEVEL EDUCATION EXPERIENCE

Saint Louis University January 2011 to December 2013
Relevant coursework in Computer Science, Computer Security, and Information Security Systems Management.

Ritsumeikan Asia Pacific University (Japan, Study Abroad) March 2012 to August 2012
Conversational Japanese

Washington University in Saint Louis August 2010 to December 2010
Studied astrobiology in an adult evening program. Astrobiology is the study of life in the universe.

Eugene Lang College The New School for Liberal Arts August 2007 to May 2008
Studied philosophy, education, and game design.

SAMPLE OF TECHNICAL SKILLS AND APTITUDES

Has attended 15 information security conferences over the last decade, including DEFCON, DerbyCon, & Toorcon. Has presented at and attended OWASP, 2600, CitySec, & local DEFCON meetings for St. Louis and Seattle chapters. Regularly attends information security meetups such as the Symbol Crash hardware security meetup in Seattle.

Programming Languages: Linux Bash, Windows Batch, PowerShell, Python, JavaScript, Java, C++, C, Rust, git
Linux Distributions: Kali Linux (penetration testing), Debian, Ubuntu, RedHat, Fedora, CentOS, Rocks (clusters)
Security Software: Burp Suite, Nmap, Metasploit, Fail2ban, IPtables, ClamAV, chkrootkit, various antivirus clients
Intrusion Detection Systems: Security Onion, Snort, Suricata, Sagan, PFsense, Tripwire, Zeek IDS
Vulnerability Analysis: Wireshark, Qualys, Nessus, Nexpose, Nmap, Nikto, Armitage, Cobalt Strike, OpenVAS
Web Hosting: LAMP (Linux+Apache+MySQL+PHP), Nginx, Lighttpd, SQLite, PostgreSQL, Oracle Database
Microsoft Office: Visio, Word, Excel, Outlook, PowerPoint, and Open Source option(s) LibreOffice, Abiword

Lifetime OWASP Member
Dell Certified Systems Expert D.C.S.E. #519346

Offensive Security Kali Linux Challenge Coin #088
Bank of America CTF DerbyCon 8 Challenge Coin #003

Black Hat 2017 Mobile Application Penetration Testing Training (Android, iOS)
Social-Engineer, Inc. Open Source Intelligence for Penetration Testing (Derbycon 8 Training)
Linux Binary Analysis ELF Training from Ryan “elfmaster” O’Neill (Offensive and Defensive)
SANS Institute SEC560 GPEN Course (did not take GPEN test due to extenuating circumstances)
Black Lodge Research Hackerspace Hardware Security Training from Joe FitzPatrick (@securelyfitz)
House of Heap Exploitation Workshop from Maxwell Dulin (Toorcon 2021 Training)
Practical Web Application Security & Testing (PWST) from M.T.Taggart
Blockchain Security Zero to Hero (DEFCON 30 Workshop)

Types Dvorak keyboard layout for efficiency.

FULL-TIME VOLUNTEER WORK

City Year Los Angeles

August 2008 – September 2009

Full-time volunteer on a team of ten AmeriCorps members in piloting a service model for middle school students, which consisted of in-class and after-school tutoring. Planned weekly lessons and activities for lunchtime and after-school enrichment. Led a team of twelve middle school students through a rigorous six months of community service through a Saturday youth leadership program. Led my team's visitors program, and represented City Year as an ambassador to external corporations and nonprofits at special events such as a gala at the Drucker Institute.